

Bachelor's Thesis Proposal

Purpose-based Access Control for Relational Database Management System

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

Model-driven privacy [2] (MDP) is a software development methodology in which privacy requirements are specified as models, and enforcement mechanisms are generated automatically via model transformations. MDP enables developers to specify three interconnected declarative models: a data model describing the state space of the system, a security model capturing fine-grained access control requirements, and a privacy model expressing data protection requirements, which is a particularly challenging class of privacy requirements. From these models, our methodology automatically generates a web application together with enforcement mechanisms that make it security- and privacy-aware by design.

In practice, the data is ultimately stored at the data layer. Furthermore, modern database management systems already offer native mechanisms for protecting the data. For example, modern database management systems provide views, row-level security policies, and privilege grants to protect data confidentiality.

2 Objective

In this thesis, we focus on preserving the *confidentiality* of personal data by preventing unauthorized access in software systems backed by a relational database management system.

The high-level objective of this thesis is to apply the idea of model-driven privacy to generate or rewrite SQL queries so that they are privacy-aware, i.e., queries that automatically enforce privacy policies.

More specifically, given a privacy model, the goal is to generate SQL enforcement artifacts: either (a) a set of SQL *views* that expose exactly the authorized subset of personal data to each data subject, or (b) *authorization checks*. The generated artifacts should guarantee that any read performed through them returns only the data that the subject is authorized to see.

3 Tasks

1. Study the existing MDP approach and access control mechanisms in relational database management systems.
2. Define a model transformation that takes the privacy model and generates SQL views and/or SQL authorization checks.
3. Implement the model transformation targeting a specific technology (e.g., MySQL).
4. Validate the approach on a case-study database, checking that reads reveal only authorized data and assessing the performance overhead.
5. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [2] Srdan Krstic, Hoang Nguyen Phuoc Bao, and David A. Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.